Focused security requirements and threat model

Give the analyst access to synthetic reports and the engineer access to maintenance instructions. Deny the unassigned user and protect administration, other lab resources and protected networks. The assignment and approved architecture define the scope.

1. Assets, actors, and boundaries

Protect privileged accounts, credentials, keys, synthetic data, logs, backup media and public submissions from unassigned users, stolen credentials, compromised devices, administrator error and disclosure.

The HP desktop runs bare-metal OPNsense, the sole router between three logical zones. The GL.iNet Beryl AX is upstream. The TP-Link TL-SG108E separates the zones across HP, the administrator path and the Dell Precision 5820. Dell runs Proxmox VE with exactly three workload virtual machines (VMs).

- **Management** holds the dedicated administrator path and named Proxmox and OPNsense interfaces.
- **Corporate** holds DC1, the Windows Server for Active Directory (AD), Domain Name System (DNS) and Group Policy, and WIN1, the Windows client.
- **Restricted** holds APP1, the Linux server for Apache HTTPS and the only workload with approved Tailscale access.

Preserve zone separation from switch ports to Proxmox bridge attachments. Each workload zone needs a physical path to HP. Workload bridges carry no host address or routing role. Keep exact cable, port, virtual LAN (VLAN), interface and bridge mappings private.

2. Mandatory security requirements

Table 1. Mandatory security requirements

Security ID	Measurable control	Requirement / test
FSC-01	Independently isolate the lab from home and production. Keep upstream disconnected until independent isolation, scoped egress and rollback are approved. Inspect both route families and verify denial at a lab-owned mock boundary.	FWR-01; FWT-01
FSC-02	Verify three zones and measured capacity for the workloads and reserves, including temporary restore space. Enforce default-deny routing on physical HP OPNsense. Verify restricted administration, supported multifactor authentication (MFA), Dell/HP console recovery and effective host rules.	FWR-02; FWT-02
FSC-03	Use the isolated ad.lab.test directory with ava, eli and uma as standard users and one separate privileged administrator. Verify standard logon, approved memberships, all six application cases and revocation.	FWR-03; FWT-03
FSC-04	Use supported Windows and Linux builds from verified media and record updates. Verify Windows Defender, host firewalls, effective Group Policy, auditing and least privilege. Give each workload one zone network interface (NIC). APP1 alone has an approved overlay. It denies input by default and blocks forwarding.	FWR-04; FWT-04
FSC-05	Use one lab-only certificate authority (CA) and one server certificate for app.ad.lab.test. Keep the CA private key encrypted and offline and restrict the server key. Install the lab public root only on approved lab clients. Verify server purpose, name, chain, validity dates and remaining lifetime. Compare trusted and untrusted browser results.	FWR-05; FWT-05

Security ID	Measurable control	Requirement / test
FSC-06	Use a separate lab-only Tailscale network (tailnet), identities, supported MFA and recovery. Allow one existing approved client to reach APP1 TCP 443 only. Keep subnet routes, exit nodes, Tailscale SSH, Funnel, Serve and public sharing off. Exclude DC1, WIN1, Proxmox and OPNsense.	FWR-06; FWT-06
FSC-07	Record five categories: directory authentication success and failure, application allow and deny, and firewall denial. Use DC1 Security, Apache and physical HP OPNsense logs. Any approved two-source alternative must cover all five. Compare source and observer times and investigate one denial against effective policy and a working control.	FWR-07; FWT-07
FSC-08	Run one reviewed WIN1 disk-capacity summary locally as a standard user. Guard the target and private output path. Verify two successful runs, invalid-target and invalid-path rejection, output against the operating system, and before/after system state.	FWR-08; FWT-08
FSC-09	Protect one encrypted off-compute APP1 backup with separate recovery-key custody. Verify external storage, scope and backup age. Restore once in isolation, verify integrity and HTTPS roles and measure actual recovery time. Preserve the original VM and sole backup.	FWR-09; FWT-09
FSC-10	Complete the five Office deliverables with reviewed evidence for every requirement and test. Protect raw records, review public artifacts and history, and use pinned read-only continuous integration (CI). Record explicit owner user acceptance testing (UAT) separately.	FWR-10; FWT-10

Isolation and egress. Under DEC-03, inspect cables, adapters, switch and bridge membership, IPv4 and IPv6 routes and forwarding, automatic routes and protected-destination aliases. Review alternate Wi-Fi, virtual private networks (VPNs), shared connections, router advertisements and DHCPv6. Keep baseline routed IPv6 disabled and retain Windows IPv6 stacks. Use lab DNS and time without corporate suffixes, forwarding or external fallback. Exclude home and production trust, federation, synchronization, credentials, identities and data. Observe real protected boundaries passively.

Approved flows. Use the FF-01 through FF-08 matrix. FF-01 restricts named management HTTPS ports to the dedicated administrator, with SSH only if approved. Local device policy controls same-zone management access and HP filters any routed leg. Windows host firewalls enforce FF-02, WIN1 to DC1 for named AD, DNS and time services within Corporate.

Physical OPNsense and destination hosts enforce FF-03 (WIN1 to APP1 TCP 443), FF-04 (APP1 to DC1, DNS TCP/UDP 53 and selected time only) and FF-05 (dedicated administrator to guests on approved named services). For FF-06, HP filters transport. The exact Tailscale grant and independent APP1 host policy restrict decrypted access. Apache enforces the page permissions.

FF-07 limits isolated egress to named components and approved update, activation and Tailscale dependencies. Block protected destinations before egress permits, including for firewall-originated traffic. FF-08 denies unlisted inter-zone traffic, ordinary-user management and protected destinations. Host restrictions apply within a zone and on the overlay. Inspect effective ingress, floating, group, automatic and anti-lockout rules, network address translation (NAT), listeners and existing states. Exclude inbound port forwarding and automatic port mapping.

Roles and trust. LabReaders starts with ava and eli, LabMaintainers with eli, and LabAdmins with the separate administrator only. Keep uma outside both app roles and standard users outside privileged groups. Group names grant no privileges. Apache maps roles manually and uses passwords distinct from AD. Run C01-C06 with valid app credentials. After approved AD and Apache changes, confirm that both existing and fresh requests deny eli's maintenance access and allow reports.

Remote verification. Replace permissive defaults before enrollment. Check effective grants, overlapping rules, device authorization, forwarding, the client's path and APP1 host policy. Demonstrate approved HTTPS, denial of an unauthorized identity and denial at a known-listening wrong port. Keep wrong-resource checks on approved lab-owned mocks. Remove the exact client's grant and device authorization. Verify denial on an actual network request from the existing browser session and from a fresh session. Record cache or connection-state handling and actual time to denial. Match results to grant, device and host evidence.

Recovery gate. Operational restore is **BLOCKED** until the owner approves the encrypted external-storage backend and recovery method, and the exact existing isolated test path through physical HP OPNsense with its disconnection and rollback procedure. Verify the encrypted mount and separate key access. Keep original APP1 off from before backup through the drill. Restore to an approved unused temporary VM ID with all restored NICs disconnected and autostart off. Verify copied Tailscale is inactive and disabled and compare file integrity to the preserved manifest before attachment. Keep nonparticipants and upstream disconnected. Use only the approved existing WIN1 path and exact temporary settings. Match HTTPS role allow and deny to policy and logs and measure restore-to-usable time with a separate clock. Disconnect and stop the copy before restoring approved settings and original APP1. Verify the final state and retain the sole encrypted backup off-compute.

Approval and evidence. Each stage A-L needs explicit owner approval for targets, actions, expected behavior, validation, stop conditions and rollback. Destructive work needs the exact disk identity and recovery plan. Installation, trust changes, enrollment, active checks and backup or restore need their named approval scope. Active isolation checks use approved lab-owned, known-listening mocks. Verify the working control and attribute each denial using the Test Plan evidence rules. Complete all 91 mandatory subchecks across the ten mapped tests. Record actual outcomes, evidence references and second observations in the five Office deliverables. An overall test passes only when all its mandatory subchecks pass with evidence. Unverified or unperformed checks remain NOT TESTED. Owner UAT stays PENDING until explicitly confirmed.

3. Threat-to-control mapping

Table 2. Threat-to-control mapping

Threat	Control / safe verification	Residual limit
Unauthorized inter-zone access or switch, VLAN or bridge bypass	FSC-01/02. Trace attachments and match routed permits and denials to HP policy and states.	A compromised hypervisor can defeat guest separation.
Same-zone lateral movement	FSC-02/04. Verify scoped Windows rules for FF-02 and effective endpoint protection.	WIN1-to-DC1 stays off the routed path.
Unrestricted management interfaces	FSC-02/04. Verify local listeners, named admin access, ordinary-user network denial and console recovery.	Same-zone access depends on host and device policy.
Privileged identity misuse or credential theft	FSC-03/04/06. Check separate privileged access, effective rights, supported MFA and recovery.	Privileged compromise can affect multiple controls.
Directory or application role escalation	FSC-03/04. Verify memberships, privileges, six app cases and revocation.	Manual role mapping can drift.
Key theft, untrusted certificates or misplaced CA trust	FSC-05/10. Verify key custody, lab trust stores and trusted and untrusted handshakes.	Software key custody depends on the operator.
Unauthorized remote overlay access	FSC-06. Match allow, deny and revoke results to grants, device state and host policy.	Additive rules and cached state need review.

Threat	Control / safe verification	Residual limit
Home or production exposure	FSC-01/02. Inspect physical and IPv4/IPv6 paths and demonstrate approved mock denial.	A shared uplink or NAT cannot prove isolation.
Firewall failure or unsafe rollback	FSC-02. Keep a private HP configuration copy and console access. Recheck flows after approved recovery.	HP loss interrupts routed access. Host controls still apply.
Lost, exposed or incorrectly restored backup	FSC-09. Verify external encryption, key custody, archive scope, file integrity and HTTPS.	Recovery evidence covers APP1 only.
Duplicate APP1 identity during restore	FSC-09. Verify original off, copy disconnected and copied Tailscale disabled before attachment.	An unintended start or reconnect breaks isolation.
Missing or misleading logs	FSC-07. Match observed action, time and effective policy to the source record.	Five events provide a bounded sample.
Automation changes unintended state	FSC-08. Check both rejections, repeat the run and inspect before/after state.	The exercise covers one local operation.
Private evidence or credential disclosure, or overstated results	FSC-10. Review content, metadata and history and trace results to actual evidence.	Automated checks have bounded coverage.

4. Historical control transition

S01-S12 apply to historical evidence and retired templates. Use FSC IDs for this specification.

Table 3. Historical control transition

Earlier controls	Current controls / disposition
S01, S06	FSC-01/02/04 retain default deny, scoped DNS and host boundaries
S02, S03	FSC-01/03/04 use the approved role counts
S04, S09	FSC-02/06 retain supported management/remote MFA and one-resource Tailscale
S05	FSC-05 uses one CA and leaf with trust and validity checks. The separate issuer and revocation service were retired
S07, S10, S12	FSC-10 and FSC-01/02/04 retain public hygiene, verified media, stage approval and separate UAT
S08	FSC-07 uses a representative sample in place of enterprise collection targets
S11	FSC-09 uses one demonstrated application restore in place of broader recovery objectives

NIST SP 800-207 provides the resource-focused verification model. Earlier NIST and Center for Internet Security (CIS) mappings remain in Git history. See the reference catalog.

5. Publication and incident handling

Keep working submissions, actual addresses, private inventories and tenant IDs, raw logs, credentials, keys, backups and production or proprietary content outside Git. Restrict log readers and retention, rotate logs and keep passwords and tokens out of them. Inspect candidate paths, staged changes, metadata, hidden content and new history and run the documentation checks. Check tracked files as well as ignore rules. On exposure, stop publication, use the owner's authorized lab revocation and rotation process, preserve private incident evidence and obtain approval before rewriting history.